

OPRAS API – QA Otomasyon Günlük Raporu

12 Ağustos 2026 · Hazırlayan: Mirac Kasapoğlu · Ortam: <https://api.opras-test.site> (dev) · Jira: [movasoftteam / proje TP](#)

237

OPERASYON

46

GEÇEN TEST

28

ŞEMA SAPMASI

11

COMMIT

1. Bugünün özeti

Gün, NadirGold QA otomasyon reposunun bir kopyasıyla başladı. Hedef bu yapıyı OPRAS API'sine uyarlamaktı. Gün sonunda elde edilen: sözleşme-güdümlü çalışan bir test altyapısı, canlı dev ortamına bağlı doğrulama araçları, bir QA panosu ve **hepsi kanıtlanmış 12 sözleşme bulgusu**.

Yapılan işler sırayla:

- NadirGold'a özel tüm veri ve çıktı repo dışına alındı (5.4 MB, silinmedi — arşivde)
- Postman koleksiyonundan OpenAPI 3.0 sözleşmesi üreten zincir kuruldu
- Auth (OTP), envelope şemaları ve testler OPRAS'a göre yeniden yazıldı
- Canlı dev ortamına bağlanıldı, 102 GET operasyonu tarandı
- QA panosu OPRAS'a uyarlandı; gerçek ID çözümleme ve otomatik yorum eklendi
- Jira erişimi kuruldu; TP-797 kartı doğrulandı ve sonuç TP-798'e yazıldı

2. Sözleşme zinciri

OPRAS servisleri canlı `docs-json` /Swagger yayınlamıyor. Elimizdeki en zengin kaynak Postman koleksiyonuydu: 391 request, 166 path ve **1041 kayıtlı örnek yanıt** (200/201 dahil 400/401/403/404/409/422/429 hata yolları). Bu örneklerden yanıt şemaları çıkarıldı.

```
opras.postman_collection.json  391 request · 1041 örnek yanıt
├─ postman_to_openapi.py → contract/openapi.json      161 path · 237 operasyon
│   └─ gen_endpoints.py → tests/api/endpoints.py      161 sabit · 33 grup
│       └─ build_registry.py → qa-dashboard/registry.json 237 kart
```

Şema çıkarımında iki karar bilinçli: `required` alanlar aynı status kodunun *tüm* örneklerinin kesişimi olarak hesaplanıyor (tek örnekte eksik olan alan zorunlu sayılmıyor, böylece yanlış pozitif contract hatası üretilmiyor) ve `additionalProperties` serbest bırakılıyor (API'ye yeni alan eklenmesi sözleşmeyi kırmıyor; yalnızca **kayıp alan** ve **tip değişimi** yakalanıyor).

Gateway'i bypass edip doğrudan servise giden 4 internal uç (`{{project_url}}` , `{{file_url}}`) sözleşme dışında tutuldu — farklı sonucu oldukları için dahil edilseler her koşulda sahte hata üretirlerdi.

Kaynak-of-truth uyarısı. Koleksiyon elle bakımlı bir dokümandır ve canlı API ondan kayabilir. Sözleşme testinin amacı tam olarak bu kaymayı ölçmektir. Servisler ileride canlı `docs-json` yayınlarsa kaynak oraya taşınmalı, koleksiyon senaryo kaynağı olarak kalmalı.

3. Canlı doğrulama sonuçları

102 GET operasyonu iki kez tarandı. İlk taramada path parametreleri yer tutucu ID ile dolduruldu; uçlar 404 döndü ve 404 sözleşmeye uygun olduğu için sonuçlar "uyumlu" görüldü. Çözümleyici eklendikten sonra aynı uçlar gerçek kayıtlarla çağrıldı:

Ölçüm	Yer tutucu ID	Gerçek ID	Değişim
2xx dönen operasyon	49	86	+37
Dokümante olmayan status	33	9	-24
Şema sapması	9	28	+19 gizliydi
Envelope sapması	1	1	—

19 şema sapması maskeliydi. Yer tutucu ID kullanıldığında uçlar 404 dönüyor, 404 sözleşmede tanımlı olduğu için sonuç yeşil görünüyor ve asıl yanıt gövdesi hiç doğrulanmıyordu. Bu, taramanın en önemli metodolojik bulgusu.

4. Bulgular

YÜKSEK B1 · Liste envelope'u yapısal olarak farklı

Koleksiyon çekirdek liste uçlarını iç içe gösteriyor, canlı düz dönüyor:

Endpoint	Canlı	Doküman
GET /v1/customers	data[] + meta	data.data[] + data.meta
GET /v1/projects	data[] + meta	data.data[] + data.meta
GET /v1/tasks	data[] + meta	data.data[] + data.meta
GET /v1/requests	data[] + meta	data.data[] + data.meta
GET /v1/quotes	data[] + meta	data.data[] + data.meta
GET /v1/users	data[] + meta	data.data[] + data.meta
GET /v1/approvals	data[] + meta	data.data[] + data.meta

Uyumlu olanlar: /v1/roles , /v1/notifications , /v1/cms/schools . **Etki:** FE response.data.data okuyorsa 7 çekirdek ekranda liste boş gelir.

YÜKSEK B2 · permissions üç ayrı şekle sahip

Aynı kavram üç farklı yapıda dönüyor. Canlı yanıt **ORM join satırını** (role_permissions) olduğu gibi dışa veriyor; gerçek izin bir seviye daha derinde:

```
GET /v1/auth/me      (canlı) → ["DASHBOARD_VIEW", "REQUEST_VIEW", ...]
GET /v1/roles/{id}   (canlı) → [{ roleId, permissionId,
                                permission: { id, code, category, description } }]
GET /v1/roles/{id}   (doküman)→ [{ id, code, category } ]
```

Şema doğrulaması bu uçta **309 hata** üretti (103 izin × 3 eksik alan) — en yüksek sapmalı uç. FE permissions[i].code okuyorsa undefined alır. **Öneri:** join satırı yerine düzleştirilmiş DTO dönülmeli ve temsil /auth/me ile hizalanmalı.

YÜKSEK B3 · Para alanı tip uyuşmazlığı

Endpoint	Alan	Canlı	Doküman
GET /v1/customers/{id}	totalRevenue	141591.45 (float)	integer
GET /v1/quotes/{id}	totalAmount	"15000.00" (string)	string

integer olarak parse eden istemci ya kırılır ya kuruşu yuvarlar. Ayrıca para temsili servisler arasında tutarsız (biri float, biri string) — tek konvansiyon belirlenmeli, tercihen string/decimal.

YÜKSEK B4 · Global envelope 403'lerde uygulanmamış

projects/notes uçlarındaki 403 yanıtları envelope yerine NestJS'in varsayılan exception filter çıktısını döndürüyor:

```
{"statusCode": 403, "message": "You can only edit your own notes", "error": "Forbidden"}
```

Diğer tüm 403'ler (`ERR_FORBIDDEN`) envelope'a uyuyor; sorun global filter'ın bu controller'da devrede olmaması. `success` alanı yok ve `error` bir nesne değil string — `error.code` üzerinden hata işleyen istemci bu üç yolda kırılır.

ORTA B5 · Yaygın nullable eksiği

Endpoint	null dönen alanlar	Neden normal
<code>/v1/tasks/{id}</code>	<code>assignedTo</code> , <code>assignedUser</code> , <code>dueDate</code> , <code>project</code>	atanmamış görev
<code>/v1/quotes/{id}</code>	<code>cancelReason</code> , <code>cancelledAt</code> , <code>cancelledByUser</code>	iptal edilmemiş teklif
<code>/v1/customers/{id}</code>	<code>taxNumber</code> , <code>taxOffice</code> , <code>vipProfile</code>	bireysel müşteri
<code>/v1/lookups/users</code>	<code>departmentName</code>	departmansız kullanıcı
<code>/v1/auth/me</code>	<code>tenantId</code>	teyit gerekiyor

Hepsi meşru durumlar; şema dolu tip bekliyor. Alanlar `nullable` işaretlenmeli. `/v1/auth/me` → `tenantId`: `null` multi-tenant bir sistemde ayrıca sorgulanmalı (test `xfail` olarak izleniyor).

BİLGİ B6 · Dokümantasyon borcu

- **401 neredeyse hiç dokümente değil:** tokensiz koşulda 102 GET ucunun 97'si 401 döndü; koleksiyon bunu yalnızca ~5 operasyonda dokümente etmiş.
- **404 dokümente değil:** 32 detay ucu var olmayan ID için doğru şekilde 404 dönüyor ama bunu dokümente etmemiş.
- **21 kısaltılmış örnek:** `{"success": false}` yazılıp `error` nesnesi atlanmış.
- **4 örnekte assertion yer tutucusu:** `$string`, `$gte:2`, `$array` gibi ifadeler gerçek veri yerine konmuş.
- `POST /v1/quotes/{id}/send` : 422 altında başarı gövdesi dokümente edilmiş.
- `GET /v1/quotes/{id}` : alan adı canlıda `quoteCode`, dokümanda `code`.

5. TP-797 kart doğrulaması

BE — Talepler / Aktiviteler Sekmesi · GET /v1/requests/{id}/activities · statü Test · Enes Solak

Kart 8 aksiyon tipi ve her biri için birebir Türkçe metin şablonu tanımlıyor. 250 talep tarandı, 307 aktivite incelendi:

Aksiyon	Görülen	Metin formatı
request_created	102	UYDU 102/102
status_changed	95	UYDU 95/95
quote_created	88	UYDU 88/88
priority_changed	9	UYDU 9/9
description_changed	5	UYDU 5/5
file_added	4	UYDU 4/4
file_removed	4	UYDU 4/4
assignee_changed	0	DOĞRULANAMADI

Regresyon bulunmadı. Zorunlu alanlar 307/307 tam (id , action , actor{id,name,avatarColor,initials} , metadata , text , createdAt). status_changed kayıtlarının tamamında fromValue/fromLabel/toValue/toLabel dolu. Kart dışı aksiyon tipi dönmüyor. BE hazır Türkçe text dönüyor, yani kartın temel şartı olan "FE metin üretmez" sağlanıyor.

Teyit gerektiren iki nokta: (1) assignee_changed canlıda hiç oluşmamış — canlı veri değiştirmemek adına bilinçli olarak tetiklenmedi. (2) Taranan 250 talebin 147'sinde hiç aktivite kaydı yok (request_created dahil); özellik öncesi kayıtlar gibi görünüyor, backfill planı sorulmalı.

Doğrulama kalıcı hale getirildi: tests/api/test_request_activities.py — kartın metin şablonları ve alan sözleşmesi kodda. Sonuç QA kartı **TP-798**'e yorum olarak yazıldı.

6. Kurulan araçlar

Araç	Ne yapar
contract/postman_to_openapi.py	Koleksiyon → OpenAPI 3.0; yanıt şemalarını 1041 örnekten çıkarır
contract/gen_endpoints.py	Spec → endpoint sabitleri (testler string literal taşımaz)
contract/sweep.py	102 GET ucunu tarar; status/dokümanite/envelope/şema/süre tablosu + markdown rapor
qa_core/resolver.py	Path parametrelerini canlı koleksiyonlardan çözümler; iç içe yollarda kademeli, önbelikli
qa-dashboard/	237 operasyonluk pano: dokümanite örnek, beklenen şema, canlı test, otomatik yorum
rag/qa_rag.py	293 belgelik offline BM25 bilgi tabanı (kaynak-referanslı)
.claude/agents/qa-endpoint-check.md	11 maddelik kontrol listesi + 6 guardrail ile QA ajanı

Güvenlik durumu

- Contract koşumu varsayılan olarak **yalnızca GET** — örnekler gerçek gövdeler olduğu için mutating koşum canlı veri yaratır/değiştirir
- Panelde mutating onay kapısı yapılandırmadan **bağımsız** olarak uygulanır
- Token yalnızca bellekte tutulur, diske yazılmaz
- Yanıt gövdesindeki PII maskelenir; pano yalnızca 127.0.0.1'e bağlanır
- Jira yazımı insan onayına tabi — ajan yalnızca taslak üretir

7. Kural setleri

Kural seti	Kapsam	Ağ
Envelope sözleşmesi (schemas/)	1041 örnek + her canlı yanıt	—
Envelope sapma baseline'ı	31 bilinen sapma, 5 kategori	hayır
Sözleşme iç tutarlılığı	4 kural: senkron, yanıt varlığı, yeni sapma, bayat girdi	hayır
Schemathesis check seti	status / content-type / şema / not-a-server-error	evet
Otomatik yorum motoru	10 kural bloğu, 4 şiddet seviyesi	hayır
Sweep değerlendirme	id / documented / envelope / schema	evet
QA ajanı kontrol listesi	11 madde + 6 guardrail	evet

Baseline mantığı: bilinen 31 sapma testi kırmaz; listede olmayan *yeni* bir sapma kırar; düzelen sapma listede kalırsa da kırar. Amaç mevcut borcu görünür kılmak ve yeni borç birikmesini engellemek.

Test kapsamı

Dosya	Test	Ağ gerekir
tests/test_analyze.py	18	hayır
tests/api/test_auth.py	6	evet
tests/api/test_smoke.py	5 (+param)	evet
tests/api/test_request_activities.py	4 (+param)	evet
tests/api/test_spec_sync.py	4	hayır
Sonuç: 46 geçti · 1 atlandı · 1 xfail (48 test toplandı)		

Atlanan test `assignee_changed` canlıda hiç oluşmadığı için; `xfail` ise `/v1/auth/me` `tenantId: null` sapması. İkisi de sessizce PASS geçmiyor, açıkça raporlanıyor.

8. Çözülen teknik sorunlar

- Spec üretimi deterministik değildi.** `merge()` nesne birleştirirken `set` üzerinde dönüyordu; Python hash randomizasyonu yüzünden property sırası her koşulda değişiyor ve CI'ın "üretilmiş dosyalar güncel mi" kontrolü sürekli kırılıyordu. Anahtarlar sıralı gezilecek şekilde düzeltildi.
- Geçersiz şema üretimi.** `pa or pb` ifadesi kullanılmıştı; ANY şeması (`{}`) Python'da falsy olduğu için `None` 'a düşüp bozuk şema ürettiyordu.
- Contract kapsamı %12'ydi.** Schemathesis örneği olmayan operasyonu atlıyordu; path parametrelerine örnek değer eklendi, kapsam 12 → 102 operasyona çıktı.
- Koleksiyon varsayılanı yanıltıcıydı.** `localhost:7000` 'de OPRAS değil macOS AirPlay dinliyor; gerçek dev adresi kullanıldı.

9. Commit geçmişi

Hash	Açıklama
e33f591	OPRAS API QA otomasyon iskeleti
42cf2cd	Türetilmiş çıktı dizinlerini <code>.gitkeep</code> ile koru
7862dd5	<code>runs/</code> yok sayımını kök <code>.gitignore</code> 'a bırak
fb8cad7	Spec üretimini deterministik yap
5bed466	Canlı dev ortama bağlan + GET tarama aracı
55e0569	Panelde otomatik OTP girişi
e82ed56	TP-797 kabul kriterlerini otomatikleştir
5bbe8b9	Panelde path parametrelerini canlıdan çözümle
93bd25e	Panelde kural tabanlı otomatik yorum ekle
1378e62	Sweep'e gerçek ID çözümleyiciyi bağla
a662937	README'de sweep bölümü + güncel kısıtlar

11 commit · 47 takip edilen dosya · yeni bağımsız repo (NadirGold geçmişi arşivde).

10. Açık işler

#	İş	Neden
1	B1/B2 için karar: liste envelope'u ve <code>permissions</code> şekli — doküman mı eski, API mi değişti?	FE entegrasyonu bu netleşmeden riskli
2	Şema sapması baseline'ı kurulması (28 sapma)	Envelope'daki gibi regresyon bekçisi; yeni sapma CI'ı kırsın
3	Para temsili konvansiyonu belirlenmesi	float / string tutarsızlığı
4	<code>assignee_changed</code> tetiklenmesi	TP-797'de doğrulanamayan tek madde
5	147 talebin aktivite kaydı yok — backfill planı	Özellik öncesi kayıtlar
6	Jira hesabına <code>TRANSITION_ISSUES</code> yetkisi	Şu an yalnızca yorum yazılabiliyor
7	<code>security</code> ve <code>boundary</code> testlerinin yazılması	Marker tanımlı, test yok (BOLA, JWT tampering, sınır değer)
8	8 uçta path parametresi çözülüyor	İlgili koleksiyonda kayıt yok; gövdeleri doğrulanmıyor

OPRAS API QA Otomasyonu · 12 Ağustos 2026 · `/Users/macbookair/MOVA`

Detaylı bulgular: `DISCREPANCIES.md` · Tam tarama tablosu: `reports/sweep-resolved-2026-08-12.md` · Baseline: `contract/envelope_exceptions.json`